

Mapeo de indicadores SQUARE GQM a objetivos nacionales y normativa

Tabla orientativa que relaciona cada métrica clave con objetivos GQM
y referencias normativas (NIS2, ENS, ISO, ENISA, etc.).

1. Tabla de mapeo

Métrica	Descripción breve	Objetivos GQM	Objetivo nacional / estratégico relacionado	Referencias normativas principales
M1.1	Cobertura de funciones de negocio críticas con requisitos de seguridad explícitos	G1	Aumentar la madurez de diseño seguro en servicios esenciales	NIS2 (gestión de riesgos, medidas técnicas), ENS (análisis de riesgos y seguridad por diseño), ISO 27001 (A.8, A.14), guías ENISA
M1.2	Cobertura de amenazas de alto impacto con requisitos mitigadores definidos	G1, G2	Reducir el riesgo residual en infraestructuras críticas	NIS2 (evaluación y tratamiento de riesgos), ENS (medidas por categoría), ISO 27005, guías ENISA de análisis de riesgos
M1.3	% de requisitos que cumplen criterios de buena ingeniería (claros, verificables, trazables)	G1	Mejorar la calidad de los requisitos de seguridad y su verificabilidad	SQUARE (calidad de requisitos), ISO/IEC 25010 (calidad del producto), ISO 29148 (ingeniería de requisitos)
M1.4	% de requisitos que superan la revisión sin observaciones críticas	G1	Asegurar consistencia y robustez en especificaciones de seguridad	SQUARE (revisión), normas de aseguramiento de calidad, buenas prácticas de ingeniería de software
M1.5	Nº medio de iteraciones de revisión de requisitos	G1	Optimizar el proceso de definición y revisión de requisitos	SQUARE (inspección), modelos de madurez de procesos (CMMI, etc.)

M2.1	Nº de activos críticos sin requisitos de seguridad asociados	G1, G2	Garantizar que todos los activos críticos están cubiertos por medidas de seguridad	NIS2 (inventario de activos, gestión de riesgos), ENS (activos y servicios), ISO 27001, guías ENISA
M2.2	% de riesgos de alto impacto con requisitos esenciales asignados	G2	Alinear gestión de riesgos con decisiones de diseño de seguridad	NIS2, ENS, ISO 27005, marcos de riesgo sectoriales
M2.3	% de requisitos mapeados a normativa aplicable (NIS2, ENS, etc.)	G2	Asegurar el cumplimiento coherente y trazable de obligaciones regulatorias	NIS2, ENS, ISO 27001, normativa sectorial (sanidad, energía, financiero)
M2.4	Frecuencia de revisión de requisitos tras incidentes o cambios significativos	G2	Fomentar la mejora continua y el aprendizaje tras incidentes	NIS2 (gestión de incidentes, lecciones aprendidas), ENS (revisión continua), ISO 27001 (mejora)
M2.5	Índice de Gestión de Mandato (IGM) para requisitos de seguridad	G2, G3	Medir el grado de cumplimiento y gobernanza de mandatos internos y regulatorios	NIS2, ENS, ISO 27001, modelos de gobernanza (COSO, ISO 31000)
M3.1	Coste anual del proceso de requisitos de seguridad	G3	Optimizar uso de recursos en seguridad por diseño	Principios de proporcionalidad en NIS2, gestión de riesgos (ISO 31000), buenas prácticas de gestión financiera
M3.2	Beneficios estimados por incidentes evitados/mitigados	G3	Justificar inversiones en requisitos de seguridad mediante reducción de incidentes	NIS2 (mitigación de riesgos), guías ENISA de análisis coste-beneficio

M3.3	Beneficios por reducción de retrabajo	G3	Reducir costes de ciclo de vida del software y sistemas	Buenas prácticas de ingeniería de software, DevSecOps, marcos de calidad
M3.4	Beneficios en auditorías/certificaciones	G3	Mejorar eficiencia en cumplimiento normativo y certificaciones	ISO 27001, ENS, auditorías sectoriales
M3.5	ROI de requisitos de seguridad	G3	Evaluar la rentabilidad global de invertir en requisitos de seguridad	Principios generales de gestión financiera y de riesgos
M3.6	Correlación entre IGM e indicadores de resultado (incidentes, sanciones, etc.)	G1, G2, G3	Validar la relación entre madurez de requisitos y desempeño en ciberseguridad	NIS2 (objetivos de reducción de riesgos), evaluaciones ENISA de estrategias nacionales

2. Uso del mapeo

Este mapeo permite:

- Conectar cada métrica técnica con objetivos políticos y regulatorios.
- Justificar la inclusión de métricas en cuadros de mando nacionales o sectoriales.
- Identificar vacíos (por ejemplo, objetivos sin métricas directas o métricas sin apoyo normativo claro).

En implementaciones reales, se recomienda:

- Añadir referencias específicas a normativa sectorial (sanidad, energía, financiero, etc.).
- Documentar en anexos las secciones exactas de las normas aplicables para facilitar auditorías y revisiones.